

Analysis of MITRE ATT&CK Techniques by Advanced Persistent Threats: APT1, APT38, and APT41

This report analyzes the MITRE ATT&CK techniques employed by three Advanced Persistent Threat (APT) groups: APT1 (Comment Crew), APT38 (Lazarus), and APT41 (Double Dragon). The groups' methodologies highlight the need for adaptive, tactics-focused defensive strategies to counter the evolving state-sponsored threats, including the use of behavioral analytics, deep packet inspection, and zero-trust principles.

APT1 (Comment Crew)

APT1's techniques include spear-phishing for initial access, using custom malware, and leveraging valid accounts to maintain persistence, with a focus on long-term data exfiltration and intelligence gathering. APT1 uses Command and Control (C2) servers to bypass network firewalls, employing techniques such as Application Layer Protocol and Encrypted Channel to disguise their communications. The group utilizes "hop points" (compromised systems) and registered domain names with benign themes to camouflage their C2 traffic and make it challenging for defenders to detect. APT1's primary impact is Economic Espionage, stealing intellectual property and sensitive business information to benefit the People's Republic of China and Chinese state-owned enterprises.

APT38 (Lazarus)

APT38, a financially motivated group, maintains access to victim environments for an average of 155 days, with a longest observed period of 678 days, to understand network layout and system technologies. The group employs various tactics, including privilege escalation, defense evasion, and credential access, using customized tools such as NESTEGG, KEYLIME, and DYEPAK. APT38's operations are characterized by significant impact, including data destruction, financial theft, and denial of service, with attempted thefts totaling over 1.1\$ billion, and are linked to North Korean IP ranges and front organizations in northeast China.

APT41 (Double Dragon)

APT41 uses various techniques for lateral movement, including Remote Desktop Protocol and Windows Management Instrumentation, and employs password brute-forcing utilities to gain access to systems. The group's collection objectives include stealing intellectual property, credentials, and in-game currencies, and they utilize techniques such as Automated Collection and Input Capture to achieve these goals. APT41 employs advanced Command and Control techniques, including Custom Protocols, Data Encoding, and Dead Drop Resolvers, which allow them to evade detection and maintain a highly responsive and adaptive C2 infrastructure.

Comparative Overview: APT38 and APT41

APT38 and APT41 are both highly advanced threat groups that employ various MITRE ATT&CK techniques, including Initial Access, Execution, Persistence, and Defense Evasion. APT38 uses techniques such as Drive-by Compromise, Exploit Public-Facing Application, and Spearphishing Attachment to gain initial access, while

APT41 uses Supply Chain Compromise, Spearphishing Attachment, and Exploits Public-Facing Application. Both groups utilize various defense evasion techniques, including Indication Removal on Host, Obfuscated Files or Information, and Code Signing, with APT41 notably using stolen digital certificates to sign their malware.

Overall Analysis: APT1, APT38, and APT41

APT1, APT38, and APT41 are three advanced persistent threat (APT) groups attributed to nation-states, with APT1 and APT41 linked to China and APT38 to North Korea. These groups employ various techniques, including credential access, internal reconnaissance, and defensive evasion, to achieve their objectives, which range from state-sponsored espionage to financial gain. The groups exhibit distinct characteristics, such as APT1’s focus on intellectual property theft, APT38’s destructive attacks, and APT41’s dual motivation of espionage and financial gain, highlighting the evolving trends in the APT landscape.

Threat Intelligence and Recommendations

To enhance detection capabilities, continuously update threat intelligence feeds with the latest indicators and Tactics, Techniques, and Procedures (TTPs). Implementing robust data backup and recovery strategies, and develop comprehensive incident response plans to mitigate the impact of attacks. Leverage MITRE ATT&CK mappings to proactively hunt for adversary behaviors within the network, focusing on identified TTPs to detect subtle signs of adversary presence.

APT	Reconnaissance	Weaponization	Delivery	Exploitation	Installation	Command and control	Actions on Objectives
APT1	System Information (recipient (eg., WEBC2- disguised as Zips, or opens WEBC2-QBP	Custom Backdoors Attachment/ (HTTP, custom), (IP theft, ipconfig, BISCUIT) Channel (SSL), data) benign files hyperlinks) file)	Spearphishing Execution Backdoors Layer Protocol Espionage Discovery (eg., Table, Ecrypted sensitive netstat	User Proxy (hop Compressed like fake PDFs	Custom Espionage (malicious clicks link	Application (eg., WEBC2, Link points, HTRAN), (RAR), Dynamic DNS	Economic Exfiltration Over C2 Channel/FTP
APT38	Thorough Passive Layer Protocol Theft (SWIFT (SWIFT users, Utilities (eg., (watering (eg., Apache Backdoors (HTTPS), fraud, 1.1\$ network NESTEGG, holes), Exploit Struts2) to (eg., Custom C2 billion activity, DYEPACK, Public-Facing execute code. NESTEGG, Protocol, attempted), org/vendor research), (Apache on SWIFT Channel, Manipulation Victim Identity Struts2), systems, Proxy (eg., on Information Spearphishing Malware for NESTEGG, (DYEPACK), (email, social Attachment, credential network WORMHOLE, Data media) Trusted gathering/ NACHOCHEESE Destruction Relationship	Drive-by Exploiting (SWIFT users, Utilities (eg., (watering (eg., Apache Backdoors (HTTPS), fraud, 1.1\$ network NESTEGG, holes), Exploit Struts2) to (eg., Custom C2 billion activity, DYEPACK, Public-Facing execute code. NESTEGG, Protocol, attempted), BLINDTOAD)	Active/ Application Financial reconnaissance Backdoors/ Compromise vulnerabilities				

					mapping		log deletion), Denial of Service, Exfiltration Over other Network Medium (fund transfers)
APT41	System Information Discovery, Network Service Discovery, Account/ Domain Trust Discovery, Gathering Intelligence	Injecting malicious code into legitimate files, Abusing stolen code- signing certificates, Obfuscate backdoors (POISONPLUG)	Spearphishing Attachment/ Link Exploit Public-Facing Application, External Remote Services, Web Shell, Supply Chain Compromise	Exploiting CVEs (eg., CVE-2019- 3369), Leveraging TeamViewer credentials	Backdoors, Bootkits, Rootkits, Scheduled Tasks, Registry Modifications, DLL search Order Hijacking	Custom Protocols, Data Encoding, Remote access Software, Dead Drop Resolver, DGA Masquerading C2 domains	Intellectual property theft, Credential theft, Stealing in- game currencies, Data Encryption for Impact, Resource Hijacking

APT1 (Comment Crew) MITRE ATT&CK Analysis

The APT1 threat actor, also known as Comment Crew, demonstrates a methodical approach across the MITRE ATT&CK framework. In the Reconnaissance phase, they gather comprehensive intelligence about victims using operating system commands and automated collection techniques, while their Resource Development includes creating custom malware families like WEBC2, BISCUIT, and GETMAIL, supported by hundreds of registered domains for Command and Control operations. Initial Access primarily relies on spearphishing campaigns with malicious attachments or links, leading to backdoor installations. For Execution, APT1 leverages built-in operating system commands and native APIs, while establishing Persistence through multiple backdoors and stolen VPN credentials. They achieve Privilege Escalation by extracting and cracking password hashes with publicly available tools, while implementing Defense Evasion through disguised malware, mimicry of legitimate traffic patterns, and SSL encryption. Their Credential Access techniques focus on password hash extraction and cracking, followed by extensive Discovery using native OS commands to map victim environments. Lateral Movement is accomplished through connections to shared resources, Remote Desktop Protocol usage, and impersonation of legitimate users with stolen credentials. Their Collection operations employ specialized tools like GETMAIL and MAPIGET to extract emails and systematically steal hundreds of terabytes of sensitive data including proprietary manufacturing processes. Command and Control utilizes application layer protocols with encryption and proxies to disguise attack origins, while Exfiltration involves RAR archiving, backdoor-based transfers, and file chunking techniques. The Impact of APT1 operations centers on economic espionage benefiting the People's Republic of China and state-owned enterprises, with additional data destruction activities to hinder forensic analysis.

APT38 (Lazarus) MITRE ATT&CK Analysis

APT38 (Lazarus) demonstrates sophisticated capabilities across the MITRE ATT&CK framework, beginning with comprehensive Reconnaissance of victim hosts, organizations, and identities, while investing heavily in Resource Development through at least 26 unique non-public malware families customized for specific operations. Their Initial Access techniques span drive-by compromises, exploitation of public-facing applications, spearphishing attachments, and leverage of trusted relationships, followed by Execution tactics utilizing command interpreters, scripting, and native APIs for malware deployment and credential gathering. APT38 establishes Persistence through boot or logon autostart execution mechanisms, deploying both active and passive backdoors particularly on SWIFT systems, and maintaining access for an average of 155 days. For Privilege Escalation, they exploit system vulnerabilities and utilize compromised credentials, while implementing extensive Defense Evasion through obfuscated files, masquerading techniques, and deliberate impairment of defensive mechanisms. Their Credential Access operations leverage specialized tools like KEYLIME to harvest banking credentials, complemented by Discovery techniques that methodically map victim networks. Lateral Movement is achieved through compromised accounts and remote services, enabling their Collection of financial transaction data, particularly targeting SWIFT systems. Command and Control operations utilize tools like NACHOCHEESE to establish covert communication channels, while Exfiltration involves staged data transfers of banking information. The Impact of their operations is particularly severe, including financial theft targeting banks globally, data destruction using tools like BOOTWRECK and CLEANTOAD to destroy evidence, and deployment of ransomware like HERMES as a distraction technique to complicate attribution and investigation efforts.

APT41 (Double Dragon) MITRE ATT&CK Analysis

The APT41 (Double Dragon) threat group exhibits a comprehensive attack lifecycle across all MITRE ATT&CK tactics. They begin with targeted reconnaissance of public-facing applications and vulnerability scanning, while developing custom malware families like POISONPLUG and HIGHNOON. Their initial access typically leverages exploited web applications, spear-phishing campaigns, and notably, supply chain compromises like the CCleaner incident. Once inside, they execute malicious code via PowerShell scripts and scheduled tasks, establishing persistence through registry modifications and web shells. For privilege escalation, they exploit system vulnerabilities and use process injection techniques, while evading defenses with stolen code-signing certificates and living-off-the-land binaries. APT41 accesses credentials through tools like Mimikatz, conducts thorough network discovery with custom tools, and moves laterally using RDP and stolen credentials. They collect sensitive data through keylogging and email harvesting, maintaining command and control via encrypted channels and tunnelers like WORMHOLE. Data exfiltration involves compression and scheduled transfers, often manipulated using frameworks like DYEPAK. Their impact is severe, including data destruction, denial of service attacks, and sophisticated financial theft attempts exceeding \$1.1 billion through manipulation of banking systems, causing significant disruption to victim networks.